

Clause	Measure & Documentation Typically Subject to Desk Audit	Potential Verification for Onsite Audit	Attributes of and Suggestions for Onsite Audit What auditor should look for in policy, procedure, activity
Data Information and Security		DEFINITION: Consumer information includes any information identifiable to one or more consumers, including that found in vendor reports, spreadsheets, consumer reports, paper or electronic information management systems, faxed documents, and client communications.	
1.1 Information Security			
CRA shall have a written information security policy. CRA shall designate one or more individuals within the organization who are responsible for implementing, managing and enforcing the information security policy.	CRA shall provide written information security policy.	CRA shall present written information security policy. If questioned, CRA employees should demonstrate knowledge of information security policy and be able to access current policy.	This is an overarching information security policy which broadly addresses security within the CRA environment. This policy may reference other security policies and/or procedures dealing with specific security topics. The security topics addressed may include some or all of the following, but are not limited to: confidentiality agreements with vendors and employees; physical security of consumer information; electronic security of consumer information; communicating consumer information to vendors, clients, and other parties; providing and communicating information to consumers; permissible uses of portable and/or removeable electronic storage devices.
	CRA shall employ or retain a minimum of one person who is responsible for CRA's overall information security program. This will be evidenced by written job description, policy, procedure, or other documentation. If various people are responsible for different aspects of the program, one person shall hold overall responsibility as evidenced by job description, organizational chart, or other documentation.	CRA shall present written job description, policy, procedure or other documentation which identifies, by name and/or title, the person responsible for the overall information security program.	CRA shall make available documentation which clearly identifies person, by name and title, who is responsible for overall information security program.
1.2 Data Security			
CRA shall have procedures in place to protect consumer information under the control of the CRA from internal and external unauthorized access. These procedures shall include specifications for the securing of information in both hard copy and electronic form, including information stored on portable and/or removable electronic devices.	CRA shall provide written procedures in place to protect consumer information from unauthorized electronic and/or physical access. This includes the collection, use, storage, and destruction of consumer information in both paper and electronic form.	CRA employees dealing with consumer information shall be able to explain and demonstrate procedures for protecting consumer information in their possession, whether such information is used internally and/or externally, and be able to access current documentation. CRA will also be able to demonstrate electronic and physical protection of consumer information.	The policies and procedures designed to protect consumer information may include some or all of the following, but are not limited to: 1) securing unattended workstations, 2) limited access to networks, data, and work areas, 3) limiting consumer information provided to information sources to only that information which is needed to conduct a search, 4) destruction of hard copy documents, 5) identification of caller before providing consumer information, 6) employee badging or other identification system, 7) unescorted visitor policy, 8) secure document destruction, 9) secure transport of information, 10) use of encryption and/or secure networks and/or websites, 11) password assignment and replacement, 12) controlling use of portable storage devices, 13) alarm systems, 14) door locks, and 15) secure server and back-up sites.
1.3 Intrusion and Data Security			
CRA shall have procedures in place to detect, investigate and respond to an information system intrusion, including consumer notification where warranted.	CRA shall provide procedures for detecting and identifying information system intrusions (unauthorized access to computer systems and/or consumer data).	CRA shall make available the procedure, process, and/or tools used to monitor access and identify potential intrusions.	CRA should be able to present proof of tools used to protect network, data, and consumer information. This may be intrusion/detection testing results, firewall protections used, secure website, etc.